

LLM-ERP 系統架構藍圖 (繁體中文) — v3.0

給 IT 主管 / 系統架構師 / 資安顧問 從 1 個客戶到 1000 個客戶，這個系統要怎麼長？防禦縱深、HA、災備、可觀測性 — 全部攤開。

⚡ **v3.0 戰略軸轉通知**：Port matrix / 部署圖可能仍顯示 Expo (8081)、LINE Webhook (TLS) 等舊埠。v3.0 已砍 mobile / LINE。實際部署只需開：80/443 (Web) / 5432 (PostgreSQL) / 6379 (Redis) / 9000-9001 (MinIO)。



目錄

- [1. 七層架構 \(Defense in Depth \)](#)
- [2. Port Matrix](#)
- [3. 防火牆規則範本](#)
- [4. TLS / PKI 架構](#)
- [5. Secrets Management](#)
- [6. HA 藍圖 \(1 → 1000 客戶演進 \)](#)
- [7. 災難復原 RPO/RTO](#)
- [8. Multi-tenant 隔離 4 層防線](#)
- [9. Observability 三柱](#)
- [10. Cost-of-Ownership 演進](#)

1. 七層架構 (Defense in Depth)

L0 · Edge (CDN / Cloudflare / DDoS / WAF / TLS Termination)



L1 · Reverse Proxy (nginx / Caddy)

- HTTPS only / HSTS
- Rate limit (層級 1 – IP)
- Security headers + CSP



L2 · API Gateway (FastAPI middleware stack)

- SecurityHeaders → RequestID → Auth (JWT) → Audit
- Rate limit (層級 2 – user_id)



L3 · Application (12 Domain Services + 10 Agent + 26 Tool)

- RBAC (5 層: Tenant→User→Role→Permission→Row Filter)
- Apply tenant_filter (一定要!)
- Apply row_filter (依 scope)



L4 · Domain Logic (Business Rules + EventBus)

- 16 Constraint Rules (如: 庫存不可負)
- SSE 即時推播
- DecisionLog (AI 互動稽核)



L5 · Data Layer (PostgreSQL + Redis Cache?)

- 連線池 (asyncpg)
- Row-level tenant_id 強制
- Audit trail



L6 · MESH Multi-Factory (WireGuard VPN)

- HQ ↔ N Factory Nodes
- 資料留在各廠 (只送聚合)

每層都是「就算上一層被穿透，這一層還會擋」。

2. Port Matrix

對外 (Public-facing)

Port	服務	暴露範圍	備註
443	HTTPS Web	Public	Cloudflare 前置
80	HTTP redirect → 443	Public	不允許明文
— (無)	LINE Bot Webhook	Cloudflare Tunnel	不開固定 port

內網 (Private LAN · office only)

Port	服務	暴露範圍	備註
8000	FastAPI backend	內網	透過 nginx 進來才接受
5173	Desktop UI (nginx)	內網	開發 / 內部使用
5432	PostgreSQL	data 網段 only	絕對不對外

MESH (多廠)

Port	服務	暴露範圍	備註
8001-8009	Factory Node	WireGuard VPN 內	各廠獨立
51820	WireGuard VPN	公網 UDP	加密通道

Observability (內部)

Port	服務	備註
9090	Prometheus	scrape /metrics
3000	Grafana	看 dashboard
9200	Elasticsearch (log)	可選

3. 防火牆規則範本

iptables / ufw (Ubuntu Server)

```
# 預設拒絕所有
ufw default deny incoming
ufw default allow outgoing

# 對外：只開 80/443
ufw allow 443/tcp comment "HTTPS"
ufw allow 80/tcp comment "HTTP→HTTPS redirect"

# 對內網辦公室 (白名單 IP)：開 SSH / dev ports
ufw allow from 192.168.0.0/24 to any port 22 comment "SSH from office"
ufw allow from 192.168.0.0/24 to any port 5173 comment "Desktop UI"
ufw allow from 192.168.0.0/24 to any port 8000 comment "Backend dev"

# MESH WireGuard
ufw allow 51820/udp comment "WireGuard"

# DB **絕不** 開外網
# 5432 不加任何規則 = 預設拒絕

ufw enable
```

Cloud Security Group (AWS / GCP)

Source	Port	Protocol	用途
0.0.0.0/0	443	TCP	HTTPS
0.0.0.0/0	80	TCP	redirect
0.0.0.0/0	51820	UDP	WireGuard
Office IP CIDR	22	TCP	SSH
Office IP CIDR	5173, 8000	TCP	Dev access
不開	5432	—	DB (透過 VPC peering)

4. TLS / PKI 架構

4.1 對外 (Public Cert)

```
[Let's Encrypt / Cloudflare]
  ↓ 90 天自動 renew
[nginx (TLS termination)]
  ↓ HTTP 內網
[backend / frontend]
```

自動 renew :

```
0 3 * * * certbot renew --quiet --post-hook "nginx -s reload"
```

4.2 內部 (mTLS — 進階)

對於高安全需求客戶 · HQ ↔ Factory Node 之間建議 mTLS :

```
[Internal CA (自建 step-ca 或 cert-manager)]
  ↓ 簽出 client + server certs
[HQ Backend] ← mTLS → [Factory Node]
```

實作 : 用 `httpx.AsyncClient(verify="/path/ca.pem", cert=("client.crt","client.key"))` 。

4.3 TLS 版本與密碼套件

```
ssl_protocols TLSv1.2 TLSv1.3;
ssl_ciphers HIGH:!aNULL:!MD5:!RC4:!DSS;
ssl_prefer_server_ciphers on;
```

禁用 : TLS 1.0/1.1 、 RC4 、 3DES 、 SHA1 簽名 。

5. Secrets Management

5.1 三層儲存

等級	儲存方式	適用
開發	<code>.env</code> 檔 (git ignore)	本機 / Demo
小客戶	<code>.env</code> + 檔案權限 600 + LUKS 加密磁碟	50-100 人廠
企業	HashiCorp Vault / AWS Secrets Manager	多廠 / 上市公司

5.2 必須輪換的 Secrets

Secret	輪換週期	工具
<code>JWT_SECRET</code>	90 天	詳見 SECRETS_ROTATION_SOP
<code>POSTGRES_PASSWORD</code>	半年	DB ROLE PASSWORD
<code>LLM_API_KEY</code>	每年	Provider console
TLS cert	90 天	Let's Encrypt 自動
WireGuard pubkey	年度	重產 + 同步
LINE Channel secret	變更時	LINE Developer Console

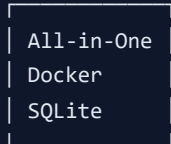
5.3 偵測機制

- 啟動時：`main.py` 偵測 `JWT_SECRET=change-me` 立刻 `log.error`
- CI：GitGuardian / TruffleHog 掃 commit 是否誤上傳 secret
- 運行時：`docker compose exec backend env | grep -i secret` 沒有預期 secret 立刻警告

6. HA 藍圖

6.1 演進路徑 (1 → 1000 客戶)

階段 1：單機 Docker (1-10 客戶)

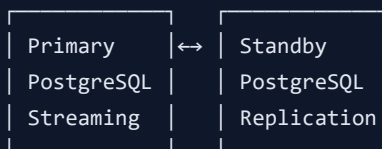


SPOF：硬碟、機器

RT0：2 小時

成本：~NT\$ 500/月 (VPS)

階段 2：雙機 Active-Passive (10-100 客戶)

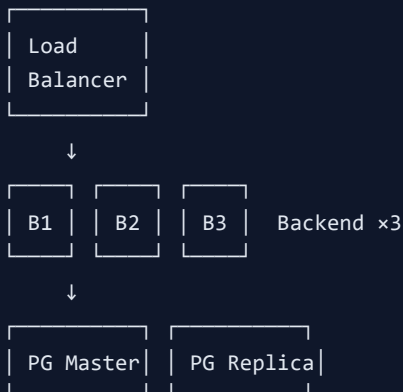


SPOF：自動 failover

RT0：5 分鐘

成本：~NT\$ 5,000/月 (兩台雲)

階段 3：負載分散 (100-500 客戶)



Read replica 給 analytics

Redis cache

RT0：< 1 分鐘

成本：~NT\$ 30,000/月

階段 4：Kubernetes / 多區域 (500+ 客戶)

Multi-region deployment

PostgreSQL HA cluster (Patroni)

Auto-scaling

CDN

RT0：seconds

成本：客單價 / 月 × 5%

6.2 何時升級？

訊號	該升級到
AI 延遲 > 10s	+ Redis cache
5+ 並發使用者	加 backend replica
DB CPU > 80%	+ read replica
跨地區客戶	multi-region
> 100 並發	Kubernetes

7. 災難復原 RPO/RTO

7.1 RPO/RTO 目標

等級	RPO	RTO	適用
基本	24 小時	2 小時	50 人廠 standard
Pro	1 小時	30 分鐘	+ WAL streaming
Enterprise	5 分鐘	5 分鐘	+ multi-region failover

詳見 [BACKUP_RESTORE_SOP_ZH.md](#)。

7.2 4 個災難情境演練

每季演練一次：

情境	演練腳本	預期 RTO
硬碟壞	換新硬碟 + 還原 daily backup	2 小時
機房失火	S3 拉過備份 + 新雲 VM	8 小時
勒索病毒	隔離 + 還原 + 資安檢查	1 小時
人為誤刪	還原 + RBAC 加強	30 分鐘

8. Multi-tenant 隔離 4 層防線

```
[第 1 道] tenant_id 欄位 (19 個業務表都有)
└─ 物理欄位存在，不可省略
    ↓
[第 2 道] 自動注入 (install_tenant_auto_injection)
└─ Session 建立物件時，依 contextvar 自動填 tenant_id
    ↓
[第 3 道] apply_tenant_filter (list/get/search endpoint 都套)
└─ WHERE tenant_id = ctx.tenant_id 強制加上
└─ ★ 即使 is_superuser=True 也不能跨租戶
└─ 唯一例外：擁有 'tenant.cross' 權限
    ↓
[第 4 道] 整合測試驗證 (tests/integration/test_tenant_isolation.py)
└─ 4 個案例：建立 / 讀取 / 反向 / ID-guessing 攻擊
└─ run_gates.sh 每次跑 – 任一失敗就紅燈
```

這是 SaaS 命脈。任一道破了 = 法律訴訟 + 信譽歸零。

9. Observability 三柱

9.1 Logging (已實作)

- 結構化 JSON (生產環境 `LOG_JSON=true`)
- 每筆都帶 `request_id` 可串聯
- 寫到 `/var/log/llm-erp/`
- 聚合：Loki / ELK / CloudWatch Logs

9.2 Metrics (規劃中)

- Prometheus 端點 `/metrics` (規劃 Phase 2)
- 關鍵指標：
 - HTTP request rate / latency / error rate
 - DB connection pool 使用率
 - LLM call count / token / cost
 - SSE 連線數

9.3 Tracing (規劃中)

- OpenTelemetry SDK
- Jaeger / Tempo 後端
- 跨 service trace：HQ → Factory Node → DB

9.4 SLO 目標

SLI	SLO	Error Budget
可用性 (status=ok)	99.9%	43 分/月
健康 API < 200ms	95%	5%
庫存查詢 < 1s	99%	1%
AI 對話 < 10s	90%	10% (LLM 依賴)

10. Cost-of-Ownership

客戶數	月雲端成本	LLM API 費	人力	總計/月
1-10 (單機)	NT\$ 500	NT\$ 1,000	0.1 FTE	~NT\$ 10,000
10-100 (雙機)	NT\$ 5,000	NT\$ 10,000	0.5 FTE	~NT\$ 50,000
100-500 (LB)	NT\$ 30,000	NT\$ 50,000	2 FTE	~NT\$ 280,000
500-1000 (K8s)	NT\$ 100,000	NT\$ 200,000	5 FTE	~NT\$ 800,000

每客戶平均月成本：~NT\$ 800-1,000 (含人力) → 客單 NT\$ 5,000/月就有 80% 毛利。

相關文件

- [系統流程拓樸](#)
- [網路部署規劃](#)
- [備份還原 SOP](#)
- [支援運維手冊](#)
- [Secrets 輪換 SOP](#)
- 對應英文版：[ARCHITECTURE_BLUEPRINT_EN.md](#)

版本：2.6 · 最後更新：2026-05-14